INFORMATION SECURITY | INSIGHT

ISO 27001:2022 Certification

From preparation to continuous improvement: the 93 Annex A controls, new controls, migration position and audit evidence.

Digital Asset Defenders | October 2026 | Security & Compliance Briefing

ISO/IEC 27001:2022 is the international standard for an information security management system (ISMS). With the 2013 edition now withdrawn, certification means demonstrating the 2022 control set and a management system that improves over time. This briefing sets out the structure, the new controls, the evidence auditors expect and how to keep the ISMS alive after the certificate arrives.

> **Status:** ISO/IEC 27001:2022 replaced the 2013 edition. The transition period ended on **31 October 2025**, so any certificate still on the 2013 edition is no longer valid. Amendment 1:2024 added climate-change considerations to clauses 4.1 and 4.2, so context and interested-party analysis should now address them.

1. Structure: clauses plus Annex A

Certification rests on two things: the management-system clauses 4 to 10 (context, leadership, planning, support, operation, performance evaluation, improvement), all mandatory, and the Annex A controls, which you select through risk assessment and justify in the Statement of Applicability (SoA).

Annex A theme	Controls	Examples
5. Organizational	37	Policies, roles, supplier security, threat intelligence, cloud services, incident management, compliance
6. People	8	Screening, terms of employment, awareness training, disciplinary process, remote working
7. Physical	14	Secure areas, clear desk, equipment siting, physical security monitoring
8. Technological	34	Access rights, MFA, malware, vulnerabilities, logging, secure coding, DLP, configuration
Total	**93**	Down from 114 in 2013, through merging, plus 11 new controls

2. The 11 new controls

Control	What auditors look for	Evidence and implementation	ATT&CK / event IDs
5.7 Threat intelligence	Collection, analysis and use of intel in risk decisions	Feeds (CERT, ISAC, vendor), triage records, detections created from intel	Supports T1190, T1566
5.23 Cloud services	Acquisition, use, management and exit of cloud services	Cloud policy, shared-responsibility matrix, CSPM reports, exit plan	T1530, T1078.004; cloud audit logs
5.30 ICT readiness for business continuity	ICT recovery tied to BIA objectives	RTO/RPO per service, restore tests, failover evidence	T1486, T1490
7.4 Physical security monitoring	Premises monitored for unauthorised access	CCTV, alarm logs, badge reports, review records	T1200
8.9 Configuration management	Baselines, change control and drift detection	CIS benchmark baselines, IaC, drift reports	4719, 4739, 5136
8.10 Information deletion	Deletion when no longer required	Retention schedule, deletion job logs, media sanitisation certificates	T1530
8.11 Data masking	Masking or pseudonymisation per policy	Masked test data, tokenisation design, access rules	CWE-359
8.12 Data leakage prevention	DLP on systems, networks and endpoints	DLP policies, alert triage, email and upload controls	T1567, T1048
8.16 Monitoring activities	Anomaly monitoring across networks and systems	SIEM use cases, alert handling, on-call rota	4624/4625, 4688, 1102, 7045
8.23 Web filtering	Access to external sites managed	Proxy/DNS filtering categories, exception process	T1189, T1071.001
8.28 Secure coding	Secure coding principles in development	Standards, SAST/DAST/SCA in CI, code review, training	CWE-79, CWE-89, CWE-798

3. Certification path

Phase	Key outputs
Scope and context	ISMS scope statement, interested parties, legal and regulatory register (including Kenya DPA 2019 and sector rules), climate consideration (Amd 1:2024)
Leadership and policy	Top-management commitment, information security policy, roles and authorities
Risk assessment and treatment	Documented method, asset and risk register, treatment plan, risk owner acceptance
SoA	All 93 controls: included or excluded, justification, implementation status
Operate and measure	Control operation records, objectives and KPIs, awareness and competence records
Internal audit and management review	Audit programme and reports (9.2); management review minutes with required inputs (9.3)
Stage 1 and Stage 2 audits	Documentation review, then operating-effectiveness audit; surveillance audits yearly; recertification at three years

4. Audit evidence that holds up

- **Documented information (7.5):** policies, SoA, risk method, procedures, with owners, versions and approval dates.
- **Records of operation:** access reviews, joiner/mover/leaver tickets, patch and vulnerability reports with CVSS and closure dates, backup restore tests, supplier assessments, incident logs with lessons learned.

- **Monitoring evidence:** SIEM rules mapped to ATT&CK techniques, sample alerts with triage notes, and log-integrity checks (event 1102 and 4719 alerting).
- **Competence and awareness:** training completion, phishing simulation results, role-specific training for administrators and developers.
- **Nonconformity handling (10.2):** corrective action records with root cause, correction and effectiveness check.

5. From certification to continuous improvement

- Track a small set of measures: mean time to detect and respond, percentage of critical vulnerabilities closed within SLA, access review completion, restore-test pass rate, training completion, supplier assessments closed.
- Feed each internal audit, incident and near miss back into the risk register and SoA. Update the SoA whenever scope, technology or threats change.
- Run one control-effectiveness deep dive per quarter (for example 8.28 secure coding in Q1, 8.16 monitoring in Q2).
- Automate evidence collection from IdP, EDR, ticketing, CI/CD and cloud posture tools so surveillance audits become a read-out, not a scramble.
- Align once, reuse many times: map the ISMS to PCI DSS v4.0.1, the Kenya DPA and CBK expectations so one control set supports several audits.

6. Frequent nonconformities

Finding	Fix
SoA exclusions without justification, or controls marked implemented without evidence	Justify each decision and link to a record
Risk assessment not repeatable or not tied to treatment decisions	Fix the method, scoring and owner acceptance
Internal audit not independent or not covering all clauses and applicable controls	Plan a full-cycle programme using competent, impartial auditors
Management review missing required inputs (audit results, nonconformities, objectives, changes)	Use a standing agenda mapped to 9.3.2
Supplier and cloud controls not evidenced (5.19-5.23)	Supplier tiering, assessments, contract clauses, exit plans